

PHISHING EMAIL DETECTION & AWARENESS REPORT

Cyber Security Task — Phishing Analysis & Employee Awareness Program

Prepared by: [Your Name]

Program: Future Interns — Cyber Security Task 2 (2026)

Date: [Submission Date]

1. Introduction

Phishing remains one of the most common and costly cyber attacks facing businesses and individuals today. Attackers use deceptive emails to trick users into clicking malicious links, downloading infected attachments, or handing over passwords, one-time codes, and financial information.

Most successful phishing attacks succeed not because of weak technical systems, but because users are not equipped to recognize the warning signs of a fake email. This is why organizations invest in phishing email analysis, employee awareness training, and internal security guidelines.

This report analyzes real phishing email samples, identifies the common indicators attackers rely on, classifies each sample's risk level, and translates the findings into practical guidance that employees can use to protect themselves and the organization.

Objective

- Analyze real phishing email samples collected from public datasets
- Identify common phishing indicators across header, sender, and content data
- Classify each email's risk level clearly (Safe / Suspicious / Phishing)
- Explain how each attack works in simple, non-technical language
- Produce prevention guidelines and a Do's & Don'ts reference for employees

Tools Used

- Public phishing email samples (rf-peixoto/phishing_pot dataset)
- Email Header Analyzer — Google Message Header Analyzer (toolbox.googleapps.com/apps/messageheader)
- MxToolbox Email Header Analyzer (mxtoolbox.com/EmailHeaders.aspx)
- Manual link/domain inspection (no links clicked)
- Word processor for report documentation

2. Methodology

- Header Analysis — checking From, Return-Path, Reply-To, and Received chains; verifying SPF, DKIM, and DMARC authentication results.
- Link & Domain Inspection — identifying the true destination of any links or buttons without clicking them, and comparing sender domains against the brand being impersonated.
- Indicator Checklist — recording every phishing red flag present, with supporting evidence from the message.
- Risk Classification — assigning a Safe / Suspicious / Phishing label with a short justification.
- Plain-English Explanation — describing how the attack works for a non-technical reader.

3. Analyzed Phishing Samples

6 email samples were analyzed, covering credential-harvesting phishing, brand impersonation, advance-fee fraud, and borderline commercial spam.

Sample 1: Fake Account Verification (Generic Template)

Subject: ⚠ Urgent: Your Account Will Be Locked
From (displayed): "Security Team" (no company name given)
From (actual domain): N/A — sample provided as body text only
Return-Path / Reply-To: N/A

Header Analysis

This sample was provided as body text only, without raw headers. In real-world analysis, the raw source should always be pulled (Gmail: "Show original"; Outlook: "View source") and passed through a header analyzer to check the From, Return-Path, and Received chain, along with SPF/DKIM/DMARC results.

Link & Domain Inspection

The call-to-action link points to `secure-account-verify[.]com`. This is a standalone domain with no relationship to any real company — it is designed purely to sound official. Legitimate account-verification links come from a company's own verified domain (e.g. `accounts.google.com`), never a generic third-party-sounding domain.

Phishing Indicators

Indicator	Present?	Evidence
Urgency / fear language	Yes	"Urgent," "24 hours," "permanent lock"
Generic greeting	Yes	"Dear User" instead of a real name
Suspicious / lookalike domain	Yes	<code>secure-account-verify[.]com</code>
Vague / unnamed sender	Yes	Signed only "Security Team"
Pressure-driven call to action	Yes	Immediate click required to avoid suspension
Spelling / grammar errors	No	None obvious in this sample

Risk Classification: Phishing (High Confidence)

Combines urgency-based social engineering, a generic greeting, and a non-corporate domain requesting credential verification — a classic credential-harvesting pattern.

Plain-English Explanation

This email tries to scare the reader into thinking their account is at risk so they click without thinking. The link goes to a fake page built to look like a real login screen — anything typed there (username, password) goes straight to the attacker.

Sample 2: Fake Microsoft "Unusual Sign-in Activity" Alert

Subject: Microsoft account unusual signin activity
From (displayed): "Microsoft account team"
From (actual domain): u6x5m@mf2g7kdiqv.com (random alphanumeric domain, unrelated to Microsoft)
Return-Path / Reply-To: Return-Path: bounce@bynatdeelie.co.uk · Reply-To: assistant.supp0rt.acc0unt@gmail.com

Header Analysis

Three unrelated domains appear across a single message: the sender domain (mf2g7kdiqv.com), the Return-Path domain (bynatdeelie.co.uk), and the Reply-To address (a free Gmail account). SPF, DKIM, and DMARC all failed or returned "none" per the Authentication-Results header. The Reply-To address also uses zero-for-"o" character substitution (supp0rt, acc0unt) to imitate "support account" while evading basic text filters — Microsoft would never use a personal Gmail address for account security correspondence.

Link & Domain Inspection

The "Report The User" button is not a link to a real Microsoft security page at all — it is a mailto: link that sends an email to the same suspicious Gmail address. The message also contains a hidden 1x1 pixel tracking image loading from thebandalisty.com, used to confirm the recipient's address is active for future targeting.

Phishing Indicators

Indicator	Present?	Evidence
Sender domain mismatch	Yes	Display name says Microsoft; real domain is mf2g7kdiqv.com
Failed SPF / DKIM / DMARC	Yes	All three failed per headers
Urgency / fear language	Yes	"Unusual sign-in," flagged foreign country (Russia/Moscow)
Fake action link (mailto instead of real URL)	Yes	"Report The User" routes to a Gmail address
Hidden tracking pixel	Yes	Invisible 1px image beacon from thebandalisty.com
Lookalike free-mail reply address	Yes	Gmail address using 0-for-o substitution

Risk Classification: Phishing (High Confidence)
--

Complete sender/domain mismatch confirmed by failed SPF/DKIM/DMARC, a fake action link, and a tracking pixel — a textbook "engagement bait" template designed to confirm live inboxes for further targeting.

Plain-English Explanation

This email pretends to be a Microsoft security alert saying someone in Russia logged into your account. The "Report The User" button doesn't go to Microsoft at all — it just sends an email to the attacker. Even opening the email quietly confirms the address is real and active, putting it on a list for further phishing attempts.

Sample 3: Fake PayPal "\$90 Exclusive Offer"

Subject: Re: 2nd attempt for [recipient]
From (displayed): "Paypal"
From (actual domain): 0a7pz@poumzenuhs.com (random alphanumeric domain, unrelated to PayPal)
Return-Path / Reply-To: Return-Path: lrvls04@lsvaim.net (a third, unrelated domain)

Header Analysis

The display name claims "Paypal" but the real sending address uses a meaningless, randomly generated domain. The Return-Path points to yet another unrelated domain, and SPF/DKIM/DMARC all failed or returned none — three different domains involved in one message is a strong automated-phishing-kit signature.

Link & Domain Inspection

Every clickable element (headline, offer banner, image, "unsubscribe" link) routes through a t.co (X/Twitter) link shortener. Shorteners are commonly abused in phishing to mask the real destination and borrow perceived trust from a recognizable platform.

Phishing Indicators

Indicator	Present?	Evidence
Sender / domain mismatch	Yes	"Paypal" display name; real domain poumzenuhs.com
Failed SPF / DKIM / DMARC	Yes	All failed per headers
Too-good-to-be-true offer	Yes	"Exclusive \$90 offer"
Obfuscated link via URL shortener	Yes	All links routed through t.co
Junk / garbled footer text	Yes	Random word list appended, likely spam-filter evasion

Risk Classification: Phishing (High Confidence)

Impersonates a trusted financial brand, hides its true destination behind a link shortener, and fails every authentication check available.

Plain-English Explanation

This message pretends to be PayPal offering free money to bait a click on a disguised link. Because the real destination is hidden behind a shortener, there is no way to verify safety before clicking — which is exactly the point.

Sample 4: "Widow's Inheritance" Advance-Fee Scam

Subject: Hi

From (displayed): shore@suksapan.or.th (likely a compromised legitimate domain)

From (actual domain): suksapan.or.th

Return-Path / Reply-To: Reply-To: elizabethray993@gmail.com (mismatched from sending domain)

Header Analysis

SPF returned a soft-fail for the sending domain, and the Reply-To address is an unrelated personal Gmail account — a mismatch between the domain that sent the mail and the address the attacker actually wants replies routed to.

Link & Domain Inspection

No links are present in this sample. Instead of a malicious URL, the message is designed purely to start a reply-based conversation with the attacker.

Phishing Indicators

Indicator	Present?	Evidence
Sender / reply-to mismatch	Yes	suksapan.or.th sends, but replies go to a personal Gmail
Failed / soft-failed SPF	Yes	SPF softfail on sending domain
Emotional manipulation	Yes	References terminal illness and a deceased spouse
Vague urgent financial proposal	Yes	"Partnership for Allocated Funds - Urgent Situation"
Asks for direct reply rather than a link	Yes	"reply to this email for more details"

Risk Classification: Phishing / Scam (High Confidence)

This is a classic advance-fee fraud ("419 scam"), a phishing subtype that skips malicious links entirely and instead manipulates the recipient into a reply-based dialogue that later leads to requests for money.

Plain-English Explanation

This message preys on sympathy and greed rather than using a malicious link. Once a recipient replies, the attacker escalates the relationship and eventually requests "processing fees" or banking details to release the fictitious funds.

Sample 5: Unsolicited Dutch Solar Panel Advertisement

Subject:  Zonnepanelen voor een goede prijs
From (displayed): "Zonnepanelen installateur"
From (actual domain): zonnepaneel@appjj.serenitepure.fr
Return-Path / Reply-To: Return-Path: return@dturm.de · Reply-To: news@aichakandisha.com

Header Analysis

This message spans four unrelated domains: the sending domain, a completely different Reply-To domain, and a fourth Return-Path domain. SPF is none and DMARC failed. While the intent here appears commercial rather than credential theft, the domain-hopping pattern is identical to phishing infrastructure.

Link & Domain Inspection

All buttons route through go.nltrck.com, a marketing click-tracking redirector rather than any legitimate solar company's own site — the true landing destination is hidden behind the redirect.

Phishing Indicators

Indicator	Present?	Evidence
Multiple mismatched sending domains	Yes	Four unrelated domains across From / Reply-To / Return-Path
Failed SPF / DMARC	Yes	SPF none, DMARC fail
Unsolicited commercial content	Yes	Unrequested sales pitch
Redirect / tracking link	Yes	All links routed through go.nltrck.com
Requests credentials or payment info	No	No credential or payment request present

Risk Classification: Suspicious

This looks more like unsolicited spam/marketing abuse than credential-theft phishing, but the domain-spoofing pattern mirrors phishing infrastructure closely enough that it should be flagged and filtered rather than dismissed as harmless.

Plain-English Explanation

This is an unsolicited ad for solar panel quotes, routed through disposable domains and a tracking redirector. Even if the underlying goal is only to generate a sales lead, the sending infrastructure is built the same way phishing campaigns are, so it merits caution.

Sample 6: Fake Bradesco Bank "Points Expiring Today" Alert

Subject: CLIENTE PRIME - BRADESCO LIVELO: Seu cartão tem 92.990 pontos LIVELO expirando hoje!

From (displayed): "BANCO DO BRADESCO LIVELO"

From (actual domain): banco.bradesco@atendimento.com.br, sent via a generic cloud VPS hostname, not banking infrastructure

Return-Path / Reply-To: Return-Path: root@ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06

Header Analysis

Despite a domain that resembles a Brazilian bank's, the message actually originates from a bare cloud VPS (a generic "ubuntu-s-1vcpu..." hostname typical of cheap rented server infrastructure), not any legitimate banking mail system. SPF returned a temporary error and DMARC failed.

Link & Domain Inspection

The "Resgatar Agora" (Redeem Now) button and all body links point to blog1seguimentmydomaine2bra.me — an unrelated, cheaply registered domain with no connection to Bradesco. The email body itself is base64-encoded, a common technique to help the message slip past simple text-based spam filters.

Phishing Indicators

Indicator	Present?	Evidence
Sent from generic cloud VPS, not a bank	Yes	Generic cloud-hosting hostname in Received headers
Failed / errored authentication	Yes	SPF temperror, DMARC fail
Urgency language	Yes	"Points expire TODAY"
Spoofed brand identity	Yes	Impersonates Bradesco / Livelos rewards program
Suspicious redemption link domain	Yes	blog1seguimentmydomaine2bra.me
Obfuscated body content	Yes	Base64-encoded HTML body

Risk Classification: Phishing (High Confidence)

Full brand impersonation of a real bank combined with urgency-based bait, hosted on unrelated throwaway infrastructure with an obfuscated payload — a textbook credential-phishing template.

Plain-English Explanation

This message pretends to be Bradesco Bank warning that rewards points expire today, pressuring the reader to click and "redeem" immediately. The link leads to a fake login page designed to steal banking credentials, not a real Bradesco site.

4. Summary of Findings

Sample	Classification	Primary Technique
Sample 1: Fake Account Verification (Generic Template)	Phishing	Urgency-based credential phishing
Sample 2: Fake Microsoft "Unusual Sign-in Activity" Alert	Phishing	Brand impersonation + tracking pixel
Sample 3: Fake PayPal "\$90 Exclusive Offer"	Phishing	Brand impersonation via link shortener
Sample 4: "Widow's Inheritance" Advance-Fee Scam	Phishing / Scam	Advance-fee / emotional manipulation scam
Sample 5: Unsolicited Dutch Solar Panel Advertisement	Suspicious	Spoofed-domain commercial spam
Sample 6: Fake Bradesco Bank "Points Expiring Today" Alert	Phishing	Brand impersonation + obfuscated payload

Common Patterns Observed

- Sender display name almost never matches the actual sending domain.
- Failed or missing SPF, DKIM, and DMARC results appeared in every phishing sample.
- Urgency and fear ("expires today," "account locked," "unusual activity") is used to short-circuit careful reading.
- Legitimate-sounding brand names are paired with unrelated or randomly generated domains.
- Link shorteners, redirectors, and mailto links are used to hide or misdirect the true destination.

5. Prevention Guidelines

How to Spot a Phishing Email

- Check the sender's actual email address, not just the display name — hover over or tap the name to reveal it.
- Be suspicious of any message creating urgency or fear ("act now," "account will be locked," "expires today").
- Never click a link before checking where it actually leads — hover to preview the URL, and watch for lookalike or shortened domains.
- Be wary of generic greetings ("Dear User") from organizations that would normally use your real name.
- Treat unexpected attachments, especially from unknown senders, as untrusted by default.
- Remember that legitimate banks, tech companies, and services will never ask for your password or OTP by email.

Do's and Don'ts for Employees

✓ Do	✗ Don't
Verify sender addresses before acting on any request	Don't trust a display name alone — it can say anything
Report suspicious emails to IT/Security immediately	Don't click links or open attachments from unknown senders
Use multi-factor authentication wherever available	Don't reuse passwords across personal and work accounts
Type company URLs directly into the browser when in doubt	Don't reply to unsolicited requests for money or personal data
Pause before acting on urgent or emotional requests	Don't assume internal-looking emails are automatically safe

6. Conclusion

The analyzed samples show that phishing relies far more on psychological manipulation — urgency, fear, sympathy, and impersonation of trusted brands — than on technical sophistication. In every phishing case examined, basic checks (verifying the sending domain, checking SPF/DKIM/DMARC results, and inspecting link destinations before clicking) would have exposed the attack.

Ongoing employee awareness, combined with straightforward technical checks, remains the most effective defense against phishing — far more so than relying on filtering technology alone.